DESIGN PROJECT – III · SEMESTER V · B.TECH, CYBER SECURITY

ThreatScope

A Reproducible SOC Detection Lab with Ground-Truth Rule Evaluation

Malepati Sree Harsha · Register No. 23CU0340018
DISC · Hindustan Institute of Technology and Science, Chennai · 2025–26

THE PROBLEM

Rules tuned by intuition, tools that can hurt

- SIEMs are heavy and opaque for learners
- Detection rules rarely ship with **ground-truth measurements**
- Nmap / ZAP misuse = scanning systems you don't own
- Goal: a **safe, measurable** SOC lab

What ThreatScope does

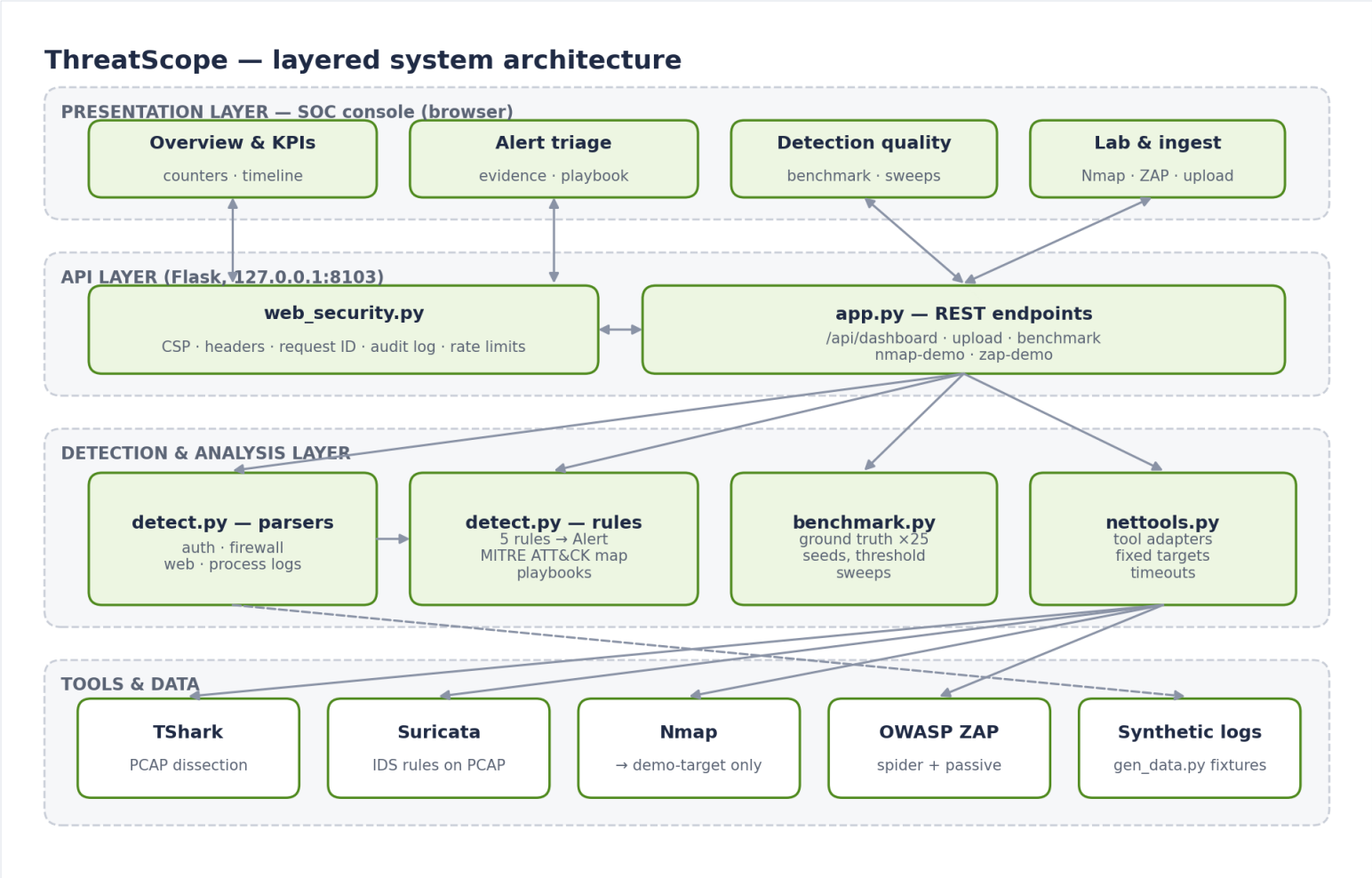
- 4 log sources + PCAP → typed events
- 5 sliding-window rules mapped to **MITRE ATT&CK**
- TShark + Suricata offline; Nmap + ZAP on an isolated target
- **Ground-truth benchmark** with threshold sweeps
- Analyst console with evidence and playbooks

What exists, and what is missing

- Snort / Suricata / Zeek: network signatures
- Wazuh, commercial SIEMs: complete but heavy
- Sommer & Paxson (2010): evaluation lacks ground truth
- **Gap:** every rule shipped with a reproducible measurement

DESIGN

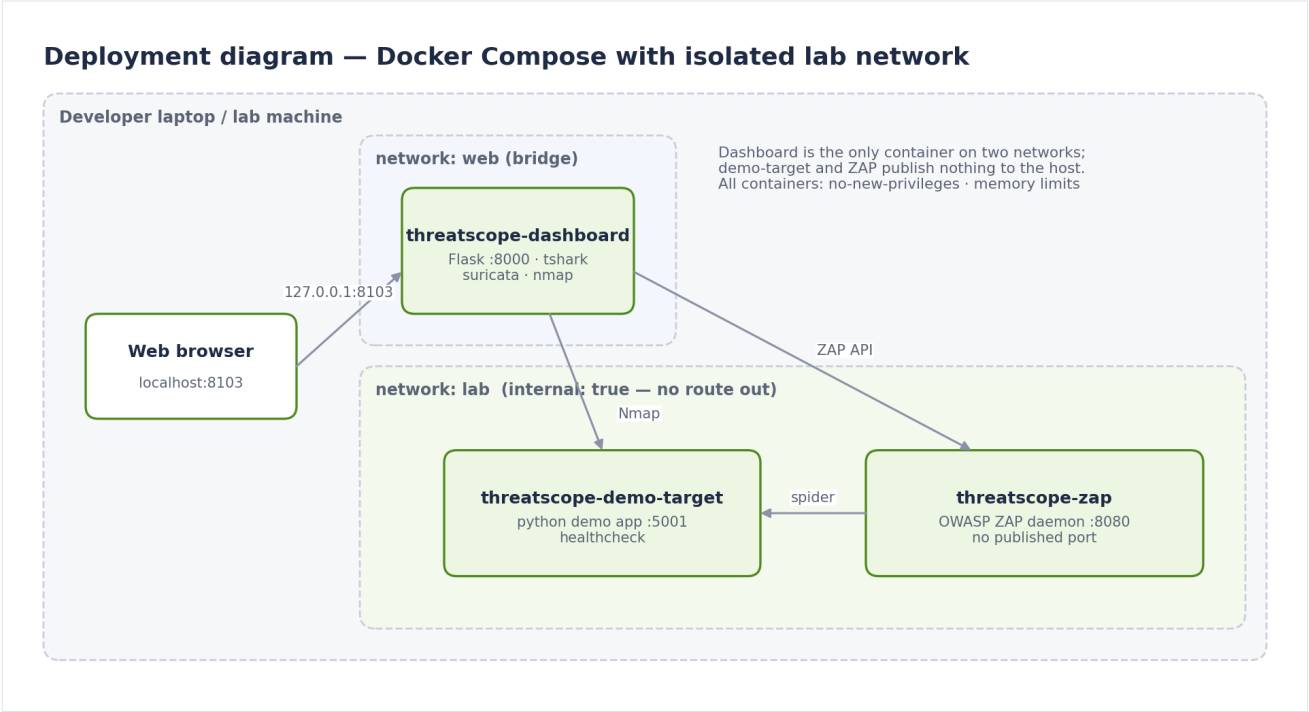
Architecture



SAFETY BY DESIGN

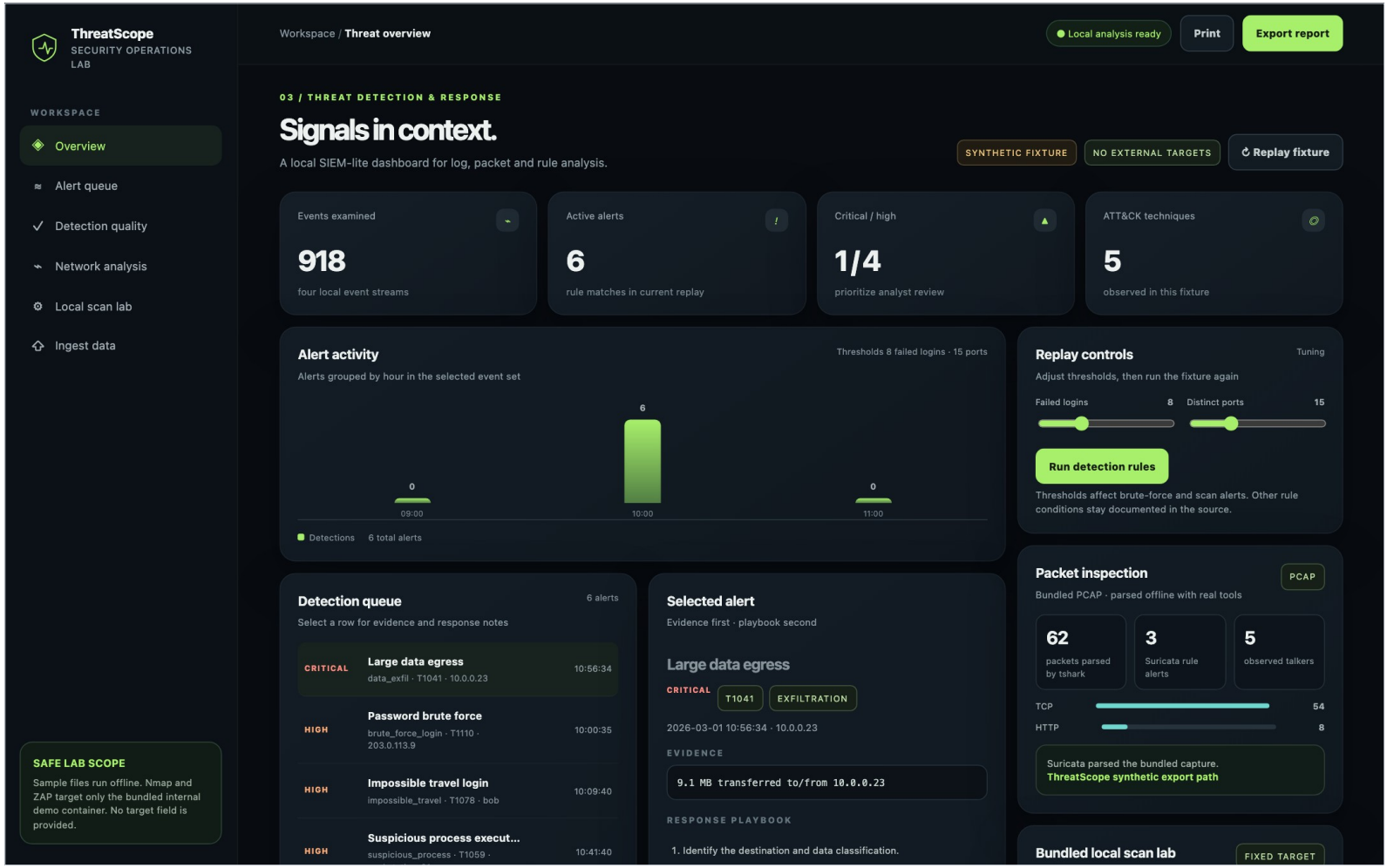
Isolated lab network

- Targets are **constants** in code
- lab network is **internal: true**
- Only the dashboard publishes a port — on 127.0.0.1
- Fixed a Compose bug that hid the console



CONSOLE

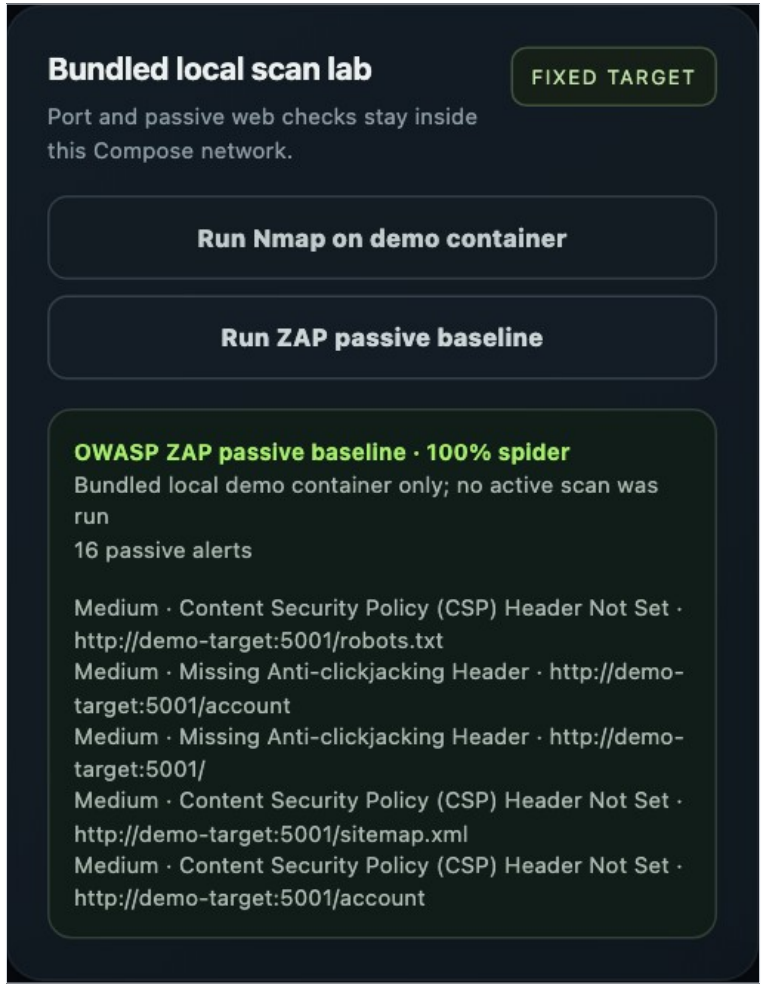
Signals in context



REAL TOOLS

TShark, Suricata, Nmap, ZAP

- TShark: **62** packets; Suricata: **3** alerts
- Nmap: 5001/tcp open on demo-target
- ZAP: **16** passive findings
- Each ZAP finding = a control ThreatScope applies itself



RESULT

Ground truth: every incident, no noise

150

true positives (25 seeds)

0

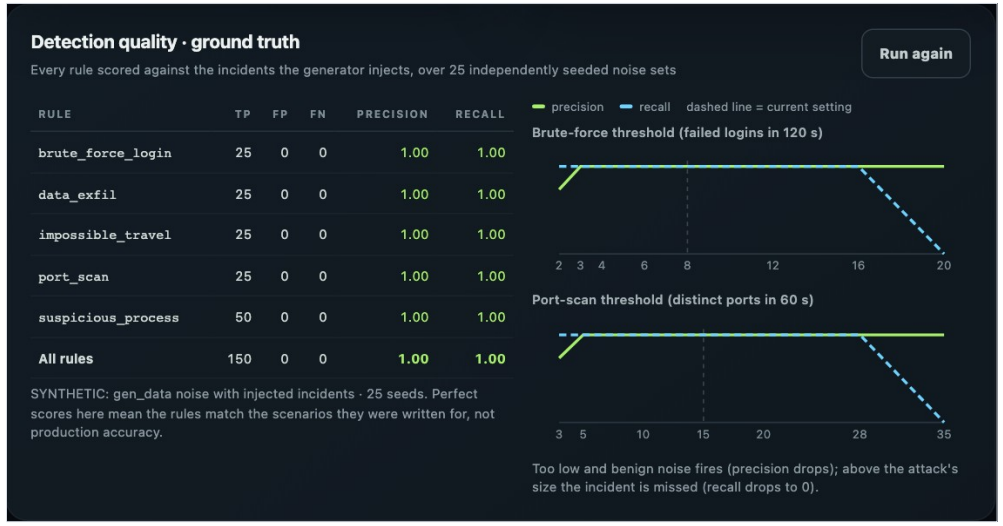
false positives

0

missed incidents

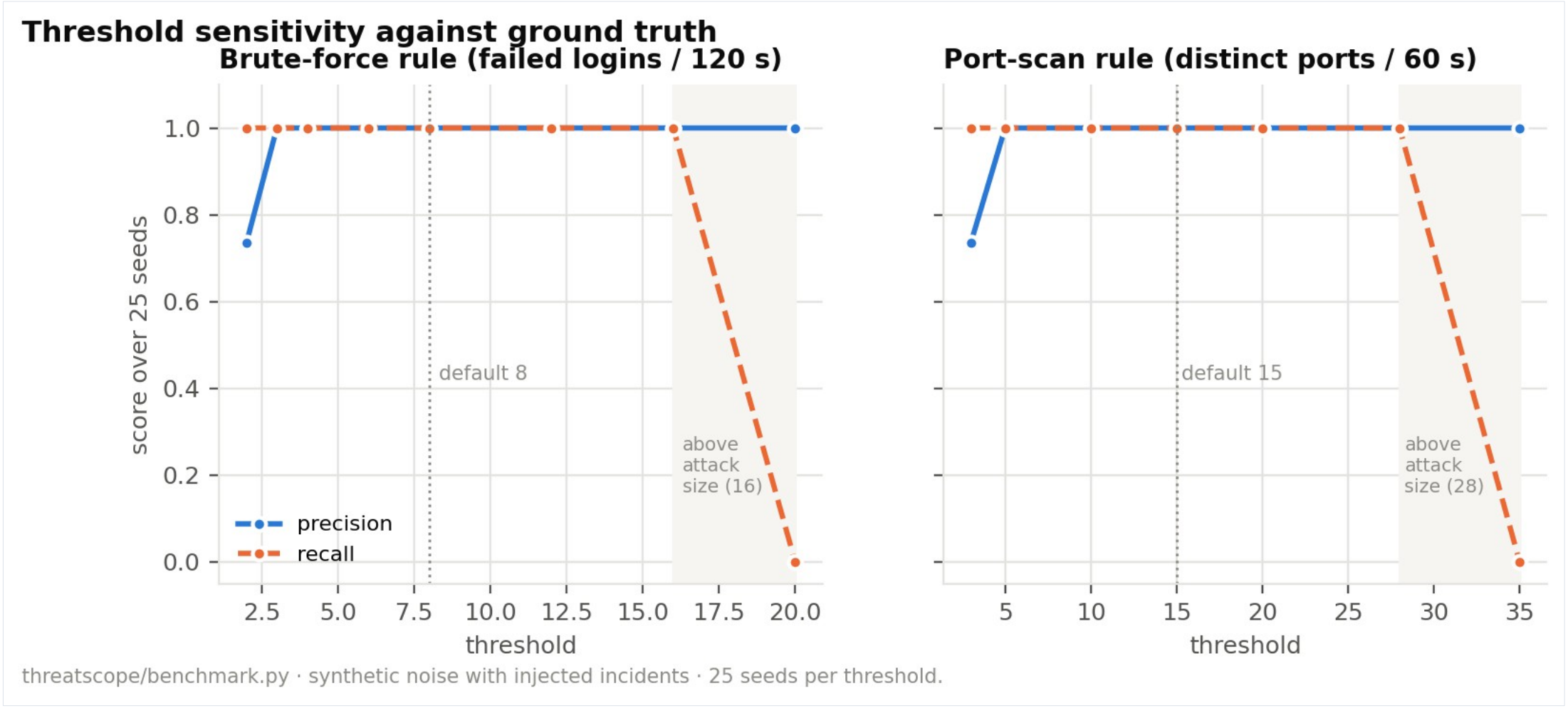
5

ATT&CK techniques



RESULT

Threshold sweeps find the safe band



SECURITY

Hardening the platform itself

- Strict CSP and OWASP headers
- Audit log for scans and auth failures; no bodies logged
- Rate limits: Nmap 4/min, ZAP 2/min, uploads 20/min
- Optional bearer-token auth (constant-time)
- **13/13** tests pass

HONEST LIMITS

Limitations and future work

- Synthetic, simple telemetry → perfect scores are expected
- No cross-source actor correlation yet
- Single shared token; no roles
- Next: Sigma rules, licensed dataset replay, case management

CONCLUSION

Measured detection engineering, safely

- Five ATT&CK rules, real tools, isolated by design
- Ground truth: 150 TP, 0 FP; sweeps show operating bands
- Built on Design Projects I (secure tooling) and II (evaluation)
- Thank you — questions?